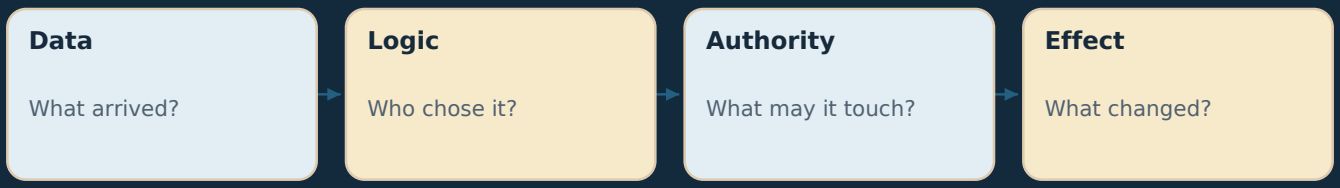
WEB SECURITY / VISUAL FIELD GUIDE

NoSQL Injection Explained

From database foundations to finding, proving, and preventing query-logic attacks



Follow the value. Find the decision. Prove the effect.

Haroon Shahid

Free preview / Introduction, roadmap and Chapters 1-3

EDITION 1.0 / HAROON SHAHID

NAVIGATION

Contents

Choose a chapter. The footer on reading pages returns here.

01 Why databases exist

02 How database models differ

03 JSON: values have shape

Reading roadmap • Next steps

ORIENTATION

Read the query boundary

Learn the data model first. Then trace each decision to a verified effect.

Lantern is a fictional two-tenant ticket catalog. Readers may choose what to search for. The server decides how to search and whose data is eligible. Follow one request from bytes to typed values, query grammar, permissions and visible results.

CENTRAL QUESTION

What did the caller supply, which decision did it reach, whose authority was used, and what can you prove happened?

1. Data and storage: Identify the expected input type, the parser that produces it, and the data model.
2. Queries and execution: Predict which records match and what the engine returns or computes.
3. Injection and impact: Identify the first input-controlled logic slot and separate the resulting effects.
4. Discovery and proof: Establish a clean baseline, a control and a bounded proof.
5. Design and defense: Repair the builder and scope, then prove valid requests still work.
6. Six other query systems: Identify the interpreter and authority boundary in six other query systems.
7. Systems and capstone: Trace, repair, verify and report a complete multi-component failure.

Predict before running. Compare a known-good request, a negative control and a candidate. New to databases? Start at Chapter 1. Developers can test themselves at Chapters 7 and 13. Reviewers can begin at Chapter 19 and revisit the foundations as needed.

This sample contains the opening three chapters. The complete edition adds discovery, seven database ecosystems, secure redesign, the workbook and the local lab.

Edition 1.0. Prepared with AI assistance. Contact: gaknt2@gmail.com.

Why databases exist

Explain the difference between a record, a query and a database.

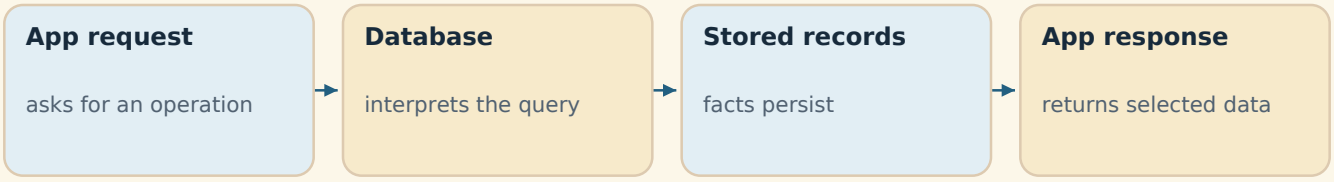
START HERE

Lantern Library lends e-books. A patron closes the app and returns tomorrow. Their loans still exist because the service stored records beyond the life of one request.

A record groups related facts. A data store keeps facts and lets a program retrieve or change them. Persistence means data survives a defined boundary, such as a process restart, under the system's durability settings. A database also provides tools for finding and changing records and can enforce certain rules about data and access.

A query asks for an operation. For a read, ask which records qualify, which fields return and in what order. For a write, ask which records qualify and what changes. A query response is one step; the application may still check permission and choose which fields the caller sees.

QUERY DECISION MAP



The app asks for loans where patronId equals P7. The database finds matches. The app returns only titles. Filtering and choosing output fields are distinct decisions.

A PICTURE TO REMEMBER

A library catalogue stores loan cards. “Look up this card number” supplies one value. “Choose how to decide who owes a book” hands over much more power.

Work the example

A first retrieval

```
Record A: id=L1, patronId=P7, title="The Harbor"
Record B: id=L2, patronId=P8, title="The Orchard"
Question: which loan has patronId equal to P7?
Answer: L1. Returning title is a separate choice.
```

WHAT COUNTS AS EVIDENCE

Write the intended operation and expected record set before testing. Otherwise a surprising result may be hard to interpret.

COMMON MISTAKE

A database returning a record does not prove that the caller can see or change it.

TRY IT

Draw where the patron identity comes from and where it is checked. Label the point that chooses records.

KNOWLEDGE CHECK / ANSWER BEFORE READING ON

1. What makes a record persistent? It survives the relevant boundary under the storage system's durability settings.

2. What is a filter? A rule for deciding which records qualify.

3. Can a query match a record the caller should not see? Yes, if query scope or output policy is wrong.

TAKEAWAY

Separate stored facts, query rules and caller permissions.

Sources: S01 · S02

How database models differ

Match access patterns to relational, document, key-value, wide-column, graph and search systems.

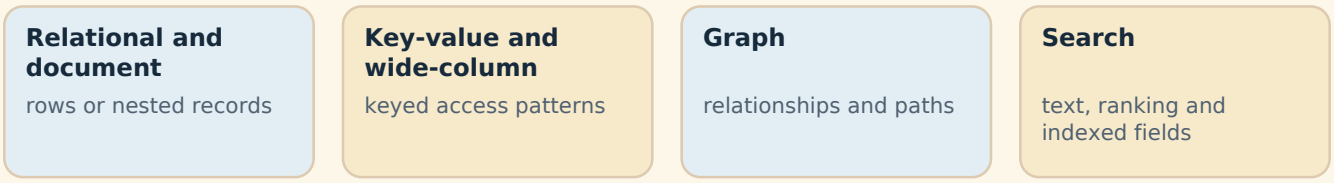
START HERE

Lantern needs loans, fast session lookups, recommendations and book search. One data model may serve several needs; each design still needs a trust boundary.

Relational stores organize data into tables and can join related rows. Document stores commonly use nested objects and arrays. Key-value stores retrieve entries by key. A wide-column store such as Cassandra organizes tables around partition and clustering keys for planned access patterns. Graph stores expose nodes, relationships and paths. Search systems index terms and often rank results.

“NoSQL” is a family label. Some stores have textual query languages, constraints, schemas or transactions. Distributed systems can offer different latency and consistency trade-offs for different operations. Choose a model based on workload and correctness needs, then inspect the actual interface.

QUERY DECISION MAP



“Find my overdue loans” could use SQL, a document filter, prepared CQL, Cypher, or a search API. Each receives different grammar and data.

A PICTURE TO REMEMBER

A filing room, a locker wall, a relationship map and a word index each make a different question easier to ask.

Work the example

Same intent, different contracts

```
Document: filter by patron and due date.
Key-value: fetch a trusted patron-scoped key.
Wide-column: query an approved partition and range.
Graph: traverse an allowed loan relationship.
Search: add an exact tenant filter plus search text.
```

WHAT COUNTS AS EVIDENCE

Find the actual driver call. A JSON HTTP response does not tell you what the database interpreted.

COMMON MISTAKE

NoSQL systems do not share an injection payload grammar. MongoDB operators are not Redis commands or Cypher keywords.

TRY IT

Choose a store for full-text search and one for loan history. Name one permission check both need.

KNOWLEDGE CHECK / ANSWER BEFORE READING ON

1. Do all NoSQL systems accept JSON queries? No. Their APIs and grammars vary.

2. Is a search index an authorization boundary by itself? No.

3. Why inspect the driver call? It reveals the real language, command or structure reaching the engine.

TAKEAWAY

Identify the model and exact API before choosing a test or a repair.

Sources: S01 · S18 · S19 · S20 · S22

JSON: values have shape

Explain why replacing a string with an object can change the result.

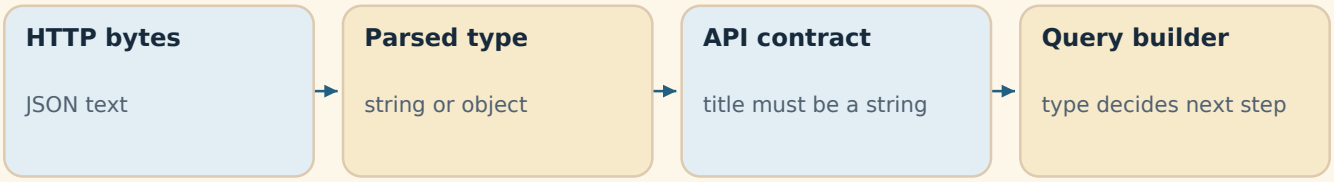
START HERE

A form submits a title. The server expects a string but accepts JSON objects. One field can now carry more than a piece of text.

JSON is text with rules for objects, arrays, strings, numbers, booleans and null. An object has named members. An array is ordered. A scalar here means one value, such as a string or a number. After parsing, "true" remains a string while true is Boolean. A quoted JSON-looking string does not automatically become a nested object.

Serialization converts values to bytes; parsing turns bytes into values. A nested object can be plain stored data or a grammar node in a query. Its role depends on where the application puts it. Duplicate member names are discouraged by the JSON standard because parsers can disagree. Decide how your boundary handles duplicates before object conversion discards evidence.

QUERY DECISION MAP



A quoted title becomes a string. An object under title remains a nested object. If the server inserts both directly into a predicate, the engine can assign different roles to them.

A PICTURE TO REMEMBER

A desk expecting one book title should not accept a folder of instructions and choose which ones to follow.

Work the example

Same field, different shapes

```
{"title":"Harbor"}               // string
{"title":["Harbor","Orchard"]}   // array
{"title":{"contains":"Harbor"}}  // object
```

WHAT COUNTS AS EVIDENCE

Keep the raw request, media type and parsed shape. Use a benign wrong-type control before claiming injection.

COMMON MISTAKE

Stripping certain characters from bytes does not enforce a contract on the parsed object.

TRY IT

Classify the four types in {"limit":"5","sort":[1,2],"active":true,"owner":null}.

KNOWLEDGE CHECK / ANSWER BEFORE READING ON

1. Does JSON parsing execute a database command? No. A downstream operation may give the parsed data meaning.

2. Where should the application enforce title's type? On the parsed value before using it to build a query.

3. Why consider duplicate keys? Two components may select different values.

TAKEAWAY

The parsed shape matters more than how the original characters look.

Sources: S03 · S04 · S10

Continue the investigation

You can now distinguish a string from an object and explain why different data models expose different operations. Next, follow the parsed value into a predicate and predict which records will match.



The full learning kit adds all 42 chapters, 126 answered checks, a workbook, revision atlas, case library and isolated local lab. Look for the full edition through the catalog where you found this preview.

This preview may be shared as an unmodified sample with attribution. For help or corrections, email gaknt2@gmail.com.